Humsafar — Security Review (checklist)

Task 6.13 · v0.1 · Owner: Syed Sarim Jawad Zaidi, paired with Muhammad Abdullah Ghafoor · Based on SDS v1.0 §17, SRS FR-N1–N3, FR-K1.3, FR-O1, NFR-03/04/10 and docs/backend/security_encryption.md (Task 6.5) · dev up to PR #78; app main 690ad51

Status so far: 29 checks: 13 pass by code or document review, 9 still need a Postman run, the app or Abdullah (the Result column is filled then), 3 differ from the SDS / SRS, 3 notes, 1 not applicable. 5 findings: 1 High, 2 Medium, 2 Low. **The High finding is in the app, not the backend.**

Status key: PASS (code) = confirmed by reading the code or contract; TO RUN = needs a Postman request, the app on a device, or Abdullah; FINDING = differs from the SDS / SRS; NOTE = acceptable now, keep in mind; N/A = does not apply.

A. Authentication and authorization (SDS 17, 11.3, FR-A4)

ID	Source	What is checked	How	Evidence	Status	Result
S-01	SDS 11.3	Passwords stored only as salted hashes	Code review	app/core/security.py: bcrypt, 12 rounds, salted; never logged	PASS (code)	
S-02	SDS 11.3	JWT signed, algorithm pinned, short access token	Code review	HS256; decode pins the algorithm (no alg=none); access 15 min, refresh 7 days	PASS (code)	
S-03	SDS 11.3	Every protected endpoint refuses a call without a token	Postman	"No token" request in every folder; 401 NOT_AUTHENTICATED (regression run, 22 folders, PR #68)	PASS (code)	
S-04	SDS 11.3	Expired access token refused; app refreshes once	App + wait 15 min	Backend returns TOKEN_EXPIRED; the app side needs a device run	TO RUN	
S-05	FR-A4	Permission checked on the server on every request, not only hidden in the app	Postman	Secondary without a module: 403 MODULE_ACCESS_DENIED in location, records, vitals, camera, analytics folders	PASS (code)	
S-06	FR-N3	Audit log readable by the Primary only; cannot be changed	Postman	Secondary 403 NOT_PRIMARY_GUARDIAN; PUT / DELETE on the path answer 405 (audit_contract.md)	TO RUN	
S-07	FR-O1	A closed account stops working at once, also with an old token	Postman	403 ACCOUNT_CLOSED on sign-in, refresh and any call (account_contract.md)	TO RUN	

B. Identity verification (FR-A2, FR-A3)

ID	Source	What is checked	How	Evidence	Status	Result
S-08	FR-A2 / A3	KYC and Guardian verification go through a provider adapter	Code review	Mock provider behind one adapter (drift D-16: real provider not used in the FYP)	NOTE	

ID	Source	What is checked	How	Evidence	Status	Result
S-09	SDS 17	Wrong phone codes and Dependent KYC passwords are rate limited	Postman	5 wrong tries in 5 minutes → 429 TOO_MANY_REQUESTS with Retry-After	TO RUN	

C. Encryption in transit (FR-N1, NFR-03)

ID	Source	What is checked	How	Evidence	Status	Result
S-10	FR-N1	Plain http refused in production; HSTS sent	Code review + Abdullah	ENFORCE_HTTPS → 400 HTTPS_REQUIRED (except /health); production start-up refuses ENFORCE_HTTPS=false	PASS (code)	
S-11	NFR-03	Audio / video end-to-end encrypted (SDS wording)	Doc review	Calls and camera go through ZegoCloud: encrypted in transit, NOT end-to-end (clarifications 140, 148). Differs from SDS 17 / NFR-03	FINDING	
S-12	FR-N1	Responses with stream tokens are not cached	Postman	GET .../camera/stream carries Cache-Control: private, no-store	TO RUN	

D. Encryption at rest (FR-N2, NFR-04)

ID	Source	What is checked	How	Evidence	Status	Result
S-13	FR-N2	Medical record files and camera clips encrypted before saving	Code review	AES-256-GCM in the application, tampering detected (security_encryption.md)	PASS (code)	
S-14	NFR-04	Health metrics and location history encrypted at rest	Doc review	Rely on the database host's disk encryption, not column encryption (clarification 149). Needs the supervisor's OK	FINDING	
S-15	FR-N2	Encryption key kept outside the repo and backed up	Abdullah	RECORDS_ENCRYPTION_KEY in .env (git-ignored); losing it makes stored files unreadable — backup step to confirm before deployment	TO RUN	

E. Camera access control (FR-K1, FR-K1.3)

ID	Source	What is checked	How	Evidence	Status	Result
S-16	FR-K1	Only the Primary and Secondaries with camera_viewing can watch; at most 3	Postman	403 MODULE_ACCESS_DENIED; 409 TOO_MANY_VIEWERS; revoked viewer cut off at next renewal	TO RUN	

ID	Source	What is checked	How	Evidence	Status	Result
S-17	FR-K1.3	The Dependent always sees who is watching	App code review	Backend sends being_viewed + viewers[]. The app's banner reads is_being_viewed / viewer_count, so as built the notice never shows (tracker, 22 Oct). Fix needed in Talha's 6.9	FINDING	

F. Wearable pairing (SDS 17 BLE)

ID	Source	What is checked	How	Evidence	Status	Result
S-18	SDS 17	Data from an unpaired or unexpected band address is not accepted	Code review	Server stores one band address per Dependent, but the sync body has no address, so only the Dependent's phone can enforce it. To check in the app when the real band lands (2.4 / 5.5); optional: send the address with each sync	NOTE	

G. Input validation and API hardening (SDS 17)

ID	Source	What is checked	How	Evidence	Status	Result
S-19	SDS 17	Every input validated against a schema	Code review	Pydantic schemas on every route (174 models); 422 VALIDATION_ERROR on bad input (regression run)	PASS (code)	
S-20	SDS 17	No hand-built SQL (injection)	Code review	SQLAlchemy only; no f-string SQL found in app/	PASS (code)	
S-21	SDS 17	Rate limits on login / register	Postman	8 wrong passwords per email in 5 minutes; 60 calls per minute per address → 429 + Retry-After	TO RUN	
S-22	SDS 17	Rate limits survive a restart / several server processes	Doc review	Counters are in memory in one process: a restart resets them; several workers would each count alone (acceptable for the FYP, note for deployment)	NOTE	
S-23	OWASP	Hardening headers on every response	Code review	nosniff, X-Frame-Options DENY, Referrer-Policy no-referrer, CORP same-origin, Permissions-Policy (transport.py)	PASS (code)	
S-24	OWASP	Cross-origin (browser) access	Code review	No CORS middleware: browsers on other sites cannot call the API. Fine for a mobile-only app; revisit if a web page is added	N/A	

H. Secrets and configuration

ID	Source	What is checked	How	Evidence	Status	Result
S-25	Repo	No real secrets committed	Repo scan	.env and *.env git-ignored; scan of tracked files found no keys or secrets; the committed Postman environment holds only a test password	PASS (code)	
S-26	Repo	Production refuses unsafe settings	Code review + Abdullah	ENVIRONMENT=production refuses to start with default / short secrets, DEBUG on, no https, no rate limits, database without ssl; run python -m app.scripts.security_audit	TO RUN	
S-27	App	Tokens stored securely on the phone	App code review	flutter_secure_storage (token_storage.dart); no token printing found	PASS (code)	

I. Data retention and privacy (FR-O1, NFR-10)

ID	Source	What is checked	How	Evidence	Status	Result
S-28	FR-O1	Closed accounts deleted / anonymized automatically after 60 days	Code review	retention_sweep job; a test fails if a new table has no retention rule (clarification 163)	PASS (code)	
S-29	NFR-10	Only needed data in replies; reading the audit log is not itself logged	Doc review	No password or hash in any reply (regression run); audit covers sensitive actions only	PASS (code)	

Findings

ID	Severity	Check	What	Action / owner
F-01	High	S-17 FR-K1.3	As built, the Dependent's "being watched" notice never appears (app reads field names the backend does not send).	Talha: re-read camera_contract.md and fix the 3 parsing methods (6.9). Re-test 6.12 K-02–K-04.
F-02	Medium	S-11 NFR-03	Video and audio are encrypted in transit by the provider, not end-to-end as SDS 17 / NFR-03 say.	Team + supervisor: accept and correct the SDS wording (drift register), or turn on the provider's end-to-end option.
F-03	Medium	S-14 NFR-04	Structured health data and locations rely on the host's disk encryption.	Supervisor's OK (already flagged by Abdullah, clarification 149); record in the drift register.
F-04	Low	S-18 SDS 17	The server cannot refuse band data from an unexpected address; only the phone can.	Talha / Abdullah when the real band lands (5.5): only read from the paired address; optional address check on sync.
F-05	Low	S-22	Rate-limit counters reset on restart and are per process.	Note for deployment (Phase 9): keep one process, or move counters to a shared store.

How to finish this review

- Sarim runs the TO RUN Postman checks in the next regression run (S-06, S-07, S-09, S-12, S-16, S-21) and fills the Result column.
- Abdullah confirms S-15 (key backup) and S-26 (security_audit script in a production-like setting) — one short session together, as the roadmap says (6.13 paired with Abdullah).
- S-04 and S-17 are re-checked on a device once Talha's APK and the 6.9 fix are available.
- F-02 and F-03 go to the drift register for the supervisor; this document does not change the locked SDS.